

Policy Gap Report — CloudScale Dynamics

GRC Advanced 1: Policy Gap Under Constraint

Prepared by: Chizaram Precious Patrick · Intern ID: UBI-2026-0099

Evidence marker: UBI-A5-264EFAFE5E84 ·

Frozen commit: 9eb95b08bb18b11bb16054eeb504314e0f7412c3

Date of analysis: 7-21-2026

1. Scope

This report reviews the security and policy gaps identified at CloudScale Dynamics using the evidence provided for this assessment. The evidence includes the Acceptable Use Policy approved on 3 September 2018, stakeholder messages from Engineering (9 July 2026) and Legal (10 July 2026), the MDM evidence record, the artifact reliability notes, and the signed `control-state.json` dated 13 July 2026.

As part of this assessment, the board approved funding for only three new security controls this quarter. These controls had to be implemented within a limit of 900 staff-hours while ensuring that 24/7 customer support remained operational. The assigned control outcomes implemented in this project are:

- `NF.IDENTITY.PRIVILEGED_ASSURANCE`
- `NF.STORAGE.RESTRICTED_PROTECTION`
- `NF.ENDPOINT.MANAGED_HEALTH`

No additional controls were added or substituted. Every other gap identified during the assessment has been given a clear treatment decision, whether to reduce, defer, or accept, along with the responsible owner and a review trigger.

Where security frameworks are referenced, I used NIST Cybersecurity Framework (CSF) 2.0 identifiers and ISO/IEC 27001:2022 Annex A control identifiers for mapping purposes only.

2. Gap register

ID	Finding	Exact Locator	Type	NIST 2.0	ISO /IEC 27001:2022
G-001	The AUP offers MFA as optional protection rather than requiring it for privileged accounts.	Legacy AUP §3	Policy	PR.AA-03	A.8.5
G-002	MFA is enabled for administrators, but no Conditional Access policy enforces it across all privileged roles. Correcting the document would not correct the tenant.	Reliability notes, Entra ID export bullet	Implementation	PR.AA-03	A.8.5

G-003	Production access is reviewed only when a manager asks. No schedule exists and no current review ticket was supplied.	Legacy AUP §6; Reliability notes, access-review bullet	Process	PR.AA-05	A.5.18
G-004	The BYOD clause permits inspection of any work device at any time with manager approval, with no informed monitoring terms or limits.	Legacy AUP §2; Legal message, 10 July 2026	Policy	GV.PO-01	A.5.34
G-005	Support attachments can contain identity documents, but no clause requires classification, encryption, or logging of that data.	Legal message, 10 July 2026; No data-handling clause in AUP §§1–8	Policy	PR.DS-01	A.8.12
G-006	The only encryption evidence is a screenshot that predates and undercounts the current estate.	MDM evidence record (Captured 18 Nov 2024, 91 devices vs. 176 current)	Evidence	ID.AM-01	A.5.9
G-007	Incidents route through a general helpdesk mailbox; one Q2 security email was routed after 31 hours.	Legacy AUP §8; Reliability notes, helpdesk bullet	Process	RS.MA-01	A.5.24
G-008	The draft keeps 90-day password rotation on the basis that frequent rotation is always safer, which current guidance does not support.	Legacy AUP §1; Colleague draft, final row	Policy	PR.AA-01	A.5.17
G-009	No documented joiner/mover/leaver process exists, although Engineering offered to automate one.	Engineering message, 9 July 2026	Process	PR.AA-05	A.5.18

3. Evidence assessment verdict for every artifact

A. MDM Dashboard Screenshot — Rejected as Evidence of Current Implementation

I did not accept the MDM dashboard screenshot as proof that encryption is fully implemented across the organisation. The screenshot was captured on 18 November 2024 and shows 91 devices, with 89 encrypted. However, the current asset inventory lists 176 company laptops, in addition to approved personal devices.

There is also no export metadata to confirm where the screenshot came from or whether it has remained unchanged. While it shows that encryption was enabled on many devices at that point in time, it does not prove that encryption is enabled across the current environment.

Based on this, I recorded it as Evidence Gap G-006. To change this verdict, I would need a current MDM export that includes metadata and can be reconciled against the latest asset inventory.

B. Entra ID Configuration Export — Accepted with Limitations

I accepted the Entra ID configuration export because it reliably shows the current configuration. It is also useful for identifying what is missing. This artifact provides the direct evidence for G-002, showing that although MFA is enabled for administrators, there is no Conditional Access policy enforcing phishing-resistant MFA across every privileged role.

C. Helpdesk Q2 Records — Accepted

I accepted the Helpdesk Q2 records as reliable evidence. The records show three security-related emails, with one security incident taking 31 hours before it reached the appropriate team.

Although the sample size is small, even a single personal data incident delayed for that long represents a weakness in the incident notification process. This evidence directly supports G-007.

D. `control-state.json` — Accepted as the Authoritative Source

I accepted `control-state.json` as the authoritative source for this project. The file is signed, versioned, and timestamped, making it the trusted source of truth for the policy engine. Every decision produced by the Policy as Code implementation is evaluated against this file, so all compliance results can be traced back to it.

E. Colleague's Draft Mapping — Not Accepted as Evidence

I did not treat the colleague's draft mapping as evidence because it is still a working document under review.

While reviewing it, I identified one significant framework mapping error in Section 4, together with at least two conclusions that go beyond what the available evidence can actually support.

4. Corrected Control Mapping

One of the biggest issues I found was the mapping of the BYOD privacy boundary. The draft linked this gap to ISO/IEC 27001:2022 A.8.12 (Data Leakage Prevention) and concluded that this control fully addressed employee monitoring requirements.

I don't agree with that conclusion. A.8.12 is intended to reduce the risk of organisational data leaving through technical controls. The concern raised by Legal is different. Their concern is whether monitoring personally owned devices is lawful, proportionate, and clearly communicated to employees.

Introducing a data loss prevention control under the existing BYOD clause would actually increase employee monitoring without first addressing the legal basis for doing so. That would increase the risk identified by Legal instead of resolving it.

For that reason, I mapped this gap to ISO/IEC 27001:2022 A.5.34 (Privacy and Protection of Personally Identifiable Information), which aligns with the NDPA requirement for lawful and proportionate processing of personal information. I kept A.8.12 where it genuinely applies, which is G-005, covering the protection of support attachments that contain personal data.

The assigned control outcomes remain exactly the same. The only change is the framework mapping, keeping the assessment within the board's funding constraints. The draft also recommends keeping the 90-day password rotation policy because it assumes frequent password changes are always more secure.

I don't believe the available evidence supports that conclusion. Current authentication guidance no longer recommends mandatory password rotation unless there is evidence that a password has been compromised. Instead of keeping the requirement without further review, I decided to defer this gap (G-008) until it can be reviewed against current security guidance.

5. Policy engine results

The three assigned controls were implemented as Policy as Code using Open Policy Agent (OPA) and Rego, with all evaluations running against the versioned `control-state.json`.

For every asset evaluated, the policy engine produces a machine-readable decision containing the control identifier, asset locator, allow or deny decision, and the relevant violation code. The resulting output is used to generate `compliance-report.json` through the documented build process. The report is generated automatically and is never edited manually.

For this assessment, the final evaluation produced 11 policy decisions, with 5 assets passing and 6 assets failing the implemented controls.

Current run: 11 decisions, 5 allowed, 6 denied.

Asset ID	Evidence Locator	Policy Decision (Outcome)
usr-102	#/identities/1	Deny — IDENTITY_MFA_WEAK
svc-201	#/identities/2	Deny — IDENTITY_OWNER_MISSING

bucket-b	#/storage/1	Deny — STORAGE_PUBLIC
dev-302	#/endpoints/1	Deny — ENDPOINT_UNMANAGED
dev-303	#/endpoints/2	Deny — ENDPOINT_EDR_UNHEALTHY
exc-01	#/exceptions/0	Deny — EXCEPTION_EXPIRED

Two results worth explaining: The first is `archive-c`. Although the storage is not encrypted, it was still allowed because it is classified as internal. The storage control implemented in this project only applies to restricted and confidential data. This was a deliberate scope decision based on the assigned control requirements, not a mistake or oversight.

The second is `dev-302`, which is linked to the only exception included in the assessment data. That exception expired on 30 June 2026, before the `control-state.json` snapshot was generated. Since expired exceptions fail closed, the endpoint is still denied, and the exception itself is also reported as a failed result. Once an exception has expired, it no longer provides any exemption from the policy.

The acceptance test suite successfully passed 41 assertions, covering all 18 published fixtures, together with additional positive tests, malformed input cases, expiry scenarios, audit logging checks, and precedence validation.

During testing, I also found an issue in my own implementation. An endpoint that did not have a recorded `last_seen` value was incorrectly being allowed because the missing field prevented the freshness rule from running. I fixed the issue, added a regression test to make sure it does not happen again, and documented the change in `decision-log.md` (D-15).

Looking back at the implementation, I believe handling missing or undefined input fields is the area that requires the most attention. It is the part of the policy I would review first in future updates because small mistakes there can unintentionally change the outcome of a policy evaluation.

6. Decisions for gaps outside the three funded controls

Gap ID	Gap	Decision	Owner	Review Trigger
G-004	BYOD inspection	Reduce. Addendum Clause 4 replaces open-ended inspection with disclosed, proportionate monitoring terms. A full	General Counsel & Security	Next policy review, NDPC guidance update, or any

		BYOD programme is deferred.		BYOD-related incident
G-005	Attachment data	Reduce. Addressed through the funded storage control and Addendum Clause 2 to improve protection of attachment data.	Security	Quarterly storage control audit
G-007	Incident escalation	Reduce. Addendum Clause 5 establishes a dedicated security escalation process with a four-hour triage target using existing tools.	Head of IT Support & Security	Quarterly review or immediately after any security incident
G-008	Password rotation	Defer. Review the password rotation requirement against current industry guidance before making changes. No funded control is allocated at this stage.	Head of Security	Annual policy review
G-009	Joiner / Mover / Leaver (JML) Process	Reduce. Engineering's proposed automation is adopted to support the funded identity control, while a full organisation-wide JML programme is deferred.	Engineering & Security	Next quarterly planning cycle

The three funded controls directly address G-001, G-002, G-003, and G-006 together with their supporting evidence requirements. I implemented only the three control outcomes assigned for this assessment and did not add, replace, or substitute any additional controls.

7. Stakeholder Resolution

During the assessment, I considered the feedback provided by both Engineering and Legal.

Engineering raised concerns about requiring security keys for every employee because of the high turnover of weekly contractors. To balance security with operational needs, the identity control only enforces phishing-resistant MFA for privileged accounts. This aligns with the approach proposed by the Vice President and includes the automated joiner, mover, and leaver (JML) process to help keep privileged access up to date after implementation.

Legal raised two separate concerns. The first was that the existing BYOD policy allows monitoring of personal devices without clearly informing employees about how that monitoring is carried out. The second was that routing potential personal data incidents through a general helpdesk mailbox is not an appropriate escalation process.

Rather than creating additional funded controls, I addressed both issues through policy addendum clauses. These clauses introduce clear monitoring boundaries for BYOD, define a dedicated security escalation process, assign responsible owners, and include review dates to ensure the changes remain effective.

8. Legal Basis and Assumptions

This assessment assumes that the Nigeria Data Protection Act (NDPA) 2023 applies because CloudScale Dynamics is a Nigerian organisation that processes customers' personal information, including support attachments that may contain identity documents.

For this reason, incidents involving personal data are treated as potentially reportable. However, before making any legal or regulatory decisions, the organisation should confirm the current notification requirements against the latest provisions of the NDPA and any guidance issued by the Nigeria Data Protection Commission (NDPC).

The identified 31-hour delay in routing one security-related email was assessed against this expectation. This is why the policy addendum introduces a four-hour triage target for potential security incidents.

9. Reconciliation

The findings in this report are consistent with the information recorded in `control-mapping.csv`, `evidence-index.csv`, and `compliance-report.json`.

Every claim made in this report is supported by a corresponding entry in the evidence index, including the artifact location, exact evidence locator, collection time, and SHA-256 hash. Likewise, every machine-generated compliance decision can be traced back to the matching entry in the compliance report.

As required by the assessment, I implemented only the three assigned control outcomes. All remaining gaps have a documented decision, an assigned owner, and a defined review trigger to support future follow-up and governance activities.